# 01-autenticacao

# Autenticação

O login devolve um token JWT. As outras rotas protegidas recebem esse token no header `Authorization: Bearer {token}`. O token vale **8 horas**; depois disso, login de novo.

---

## Login

| Método | Endpoint | Acesso |
|---|---|---|
| `POST` | `/api/auth/login` | Público |

### Body

```
{
  "email": "marina@teste.com",
  "senha": "senha1234",
  "tipo": "candidato"
}
```

| Campo | Tipo | Obrigatório | Limite / regra |
|---|---|---|---|
| `email` | texto | ✅ | e-mail válido |
| `senha` | texto | ✅ | — |
| `tipo` | texto | ✅ | só `candidato` ou `empresa` |

> O mesmo e-mail pode ter conta de candidato e de empresa, por isso o `tipo` vai junto.

**Limite de tentativas:** 5 logins por minuto por IP. A 6ª tentativa recebe `429`.

### Resposta `200`

```
{
  "token": "eyJhbGciOiJIUzI1NiIs...",
  "expiraEm": "2026-11-09T22:00:00Z",
```

```
  "usuario": { "tipo": "candidato", "id": 3, "nome": "Marina" }
}
```

Erros: `400` campo inválido · `401` e-mail ou senha incorretos · `429` muitas tentativas.

---

## Quem está logado

| Método | Endpoint | Acesso |
|---|---|---|
| `GET` | `/api/auth/me` | Logado |

### Body

Sem body.

### Resposta `200`

```
{ "tipo": "candidato", "id": 3, "nome": "Marina" }
```

Erros: `401` sem token ou token expirado.

---

## Trocar senha

| Método | Endpoint | Acesso |
|---|---|---|
| `PUT` | `/api/auth/senha` | Logado |

### Body

```
{
  "senhaAtual": "senha1234",
  "novaSenha": "outraSenha9"
}
```

| Campo | Tipo | Obrigatório | Limite / regra |
|---|---|---|---|
| `senhaAtual` | texto | ✅ | tem que ser a senha atual da conta |

| Campo | Tipo | Obrigatório | Limite / regra |
| --- | --- | --- | --- |
| `novaSenha` | texto | ✅ | **8 a 100 caracteres**; diferente da senha atual |

## Resposta `204`

Sem conteúdo.

Erros: `400` senha atual errada, nova igual à atual ou fora do limite · `401` sem token.